

NGÂN HÀNG NHÀ NƯỚC VIỆT
NAMCỘNG HÒA XÃ HỘI CHỦ NGHĨA VIỆT
NAM

Độc lập - Tự do - Hạnh phúc

Số: 09/2024/TT-NHNN

Hà Nội, ngày 20 tháng 5 năm 2024

THÔNG TƯ

Quy định về bảo đảm an toàn, bảo mật hệ thống công nghệ thông tin trong hoạt động ngân hàng

Căn cứ Luật Ngân hàng Nhà nước Việt Nam ngày 16 tháng 6 năm 2010;

Căn cứ Luật An toàn thông tin mạng ngày 19 tháng 11 năm 2015;

Căn cứ Nghị định số 88/2024/NĐ-CP ngày 15 tháng 10 năm 2024 của Chính phủ quy định về bảo vệ dữ liệu cá nhân trong hoạt động của tổ chức tín dụng;

Thông đốc Ngân hàng Nhà nước Việt Nam ban hành Thông tư quy định về bảo đảm an toàn, bảo mật hệ thống công nghệ thông tin trong hoạt động ngân hàng.

Chương I. PHÂN LOẠI HỆ THỐNG

Điều 3. Phân loại hệ thống thông tin theo cấp độ

Hệ thống thông tin của tổ chức tín dụng được phân loại từ Cấp độ 1 đến Cấp độ 5. Hệ thống thông tin trọng yếu là hệ thống từ Cấp độ 3 trở lên.

Bảng phân loại cấp độ hệ thống thông tin

Cấp độ	Tiêu chí	Ví dụ hệ thống
Cấp độ 1	Thông tin công khai	Website giới thiệu
Cấp độ 2	Nội bộ, ít nhạy cảm	Thư điện tử nội bộ
Cấp độ 3	Ảnh hưởng nhiều khách hàng	eKYC, hệ thống thẻ và ATM
Cấp độ 4	Trọng yếu	Core banking, thanh toán liên ngân hàng
Cấp độ 5	Đặc biệt quan trọng	Trung tâm dữ liệu dự phòng thảm họa

Chương II. KIỂM SOÁT TRUY CẬP

Điều 6. Xác thực đa yếu tố

- Tổ chức tín dụng phải áp dụng **xác thực đa yếu tố (MFA)** đối với mọi truy cập từ xa vào hệ thống thông tin nội bộ và đối với mọi truy cập của người dùng có đặc quyền quản trị.
- Xác thực đa yếu tố phải bao gồm tối thiểu hai trong ba yếu tố: yếu tố người dùng biết (mật khẩu), yếu tố người dùng có (thiết bị, mã OTP) và yếu tố sinh trắc học.

Điều 7. Chính sách mật khẩu

Tổ chức tín dụng ban hành chính sách mật khẩu bảo đảm độ phức tạp tối thiểu và định kỳ rà soát. Độ dài và chu kỳ thay đổi mật khẩu do tổ chức tín dụng quy định nhưng không thấp hơn mức bảo đảm an toàn thông thường của ngành.

Điều 8. Yêu cầu kiểm soát truy cập tối thiểu

Tổ chức tín dụng phải bảo đảm các yêu cầu sau:

- Áp dụng nguyên tắc đặc quyền tối thiểu (least privilege) cho mọi tài khoản;
- Thu hồi quyền truy cập trong vòng 24 giờ khi nhân sự nghỉ việc hoặc chuyển vị trí;
- Rà soát, đối chiếu danh sách tài khoản và quyền định kỳ tối thiểu 06 tháng một lần;
- Nghiêm cấm sử dụng tài khoản dùng chung cho hệ thống trọng yếu;
- Ghi nhật ký toàn bộ hành vi của tài khoản quản trị.

Chương III. GIÁM SÁT VÀ ỨNG CỨU SỰ CỐ

Điều 10. Nhật ký hệ thống

Tổ chức tín dụng phải ghi và lưu trữ **nhật ký (log)** truy cập, thao tác trên các hệ thống thông tin trọng yếu trong thời gian **tối thiểu 12 (mười hai) tháng** để phục vụ điều tra, truy vết sự cố.

Điều 11. Mã hóa dữ liệu

Dữ liệu cá nhân của khách hàng và dữ liệu xác thực phải được mã hóa khi lưu trữ và khi truyền trên môi trường mạng, phù hợp với quy định tại Nghị định số 88/2024/NĐ-CP.

Điều 12. Thời hạn báo cáo sự cố an toàn thông tin

Mức độ sự cố	Mô tả	Thời hạn báo cáo NHNN
Nghiêm trọng	Rò rỉ dữ liệu cá nhân; gián đoạn core banking	Trong 04 giờ
Trung bình	Xâm nhập trái phép chưa gây thiệt hại lớn	Trong 24 giờ
Thấp	Sự cố đơn lẻ, đã kiểm soát	Báo cáo định kỳ hàng tháng

Điều 14. Hiệu lực thi hành

Thông tư này có hiệu lực thi hành kể từ ngày **01 tháng 7 năm 2024**.

Nơi nhận:

- Các tổ chức tín dụng, chi nhánh NHNN;
- Văn phòng Chính phủ;
- Lưu: VT, CNTT;

KT. THỐNG ĐỐC PHÓ THỐNG ĐỐC
(mô phỏng)

Trần Thị B